

Penetration Test Report

Client: MEGI
Author: Sasha Rajlic
Date: 22/04/2025
Version: 1.0
Reference: AS/REP/1125



Table of Contents

DOCUMENT STRUCTURE & CONVENTIONS.....	5
EXECUTIVE SUMMARY	6
Security Posture	6
CONCLUSIONS.....	8
High Priority	8
Medium Priority	8
Low Priority	8
SCOPE OF WORK.....	9
Background	9
Targets.....	9
Environment.....	9
User Privileges & Credentials.....	9
Rules of Engagement.....	10
Assessment Constraints.....	10
TECHNICAL SUMMARY	11
ASSESSMENT FINDINGS	12
Application Penetration Test.....	12
API Misconfigured Access Control.....	12
Session Token Passed in the URL.....	16
No Session Token Expiry	17
Authorisation Token Disclosure in Django Admin Interface	18
Vulnerable Version of TinyMCE in Use	20
Lack of Anti Automation Controls.....	21
Lack of Input Validation	23

Relaxed CORS Policy	26
Missing Cookie Security Directive.....	28
Long Session Timeout	30
External Network Penetration Test.....	31
Appendix A - OWASP Top 10 Web Application Security Risks.....	32
CYBER SECURITY CERTIFICATIONS.....	33

DOCUMENT HISTORY

Version	Reviewer / Author	Comment	Date
0.1	Sasha Raljic	Initial Draft	22/04/2025
0.2	QA Team	Review	23/04/2025
0.2	Matt Jennings	Additional Review	23/04/2025
0.3	Sasha Raljic	Review Changes	23/04/2025
1.0	Sasha Raljic	Formal Release	23/04/2025

CONTACT DETAILS

Name	Role	Email	Contact Number
Sasha Raljic	Author	sasha@attackvector.uk	+44(0)7961274526
Matt Jennings	Reviewer	matt@assuric.com	-

REFERENCES

Document Reference	Date
Assuric Statement of Work	14/04/2025

DOCUMENT STRUCTURE & CONVENTIONS

This report is structured into multiple sections tailored to specific audiences. The Executive Summary targets management-level personnel and provides an overview of the issues identified during the assessment, as well as a general evaluation of the security posture of the targets in scope.

The introductory chapter summarises the objectives and scope of the assessment, which should be read together with the supporting Statement of Work.

Each section focuses on a specific assessment type and provides detailed results and recommendations. While every effort has been made to make these sections accessible to all, they are primarily aimed at a technical audience.

Critical	High	Medium	Low	Note
An issue, where threats have an extremely high degree of motivation, capability and contact with the asset, and can severely impact an asset in terms of access, modification, misuse, denying access or disclosure through a vulnerability resulting from none or critically flawed controls.	An issue, where threats have a high degree of motivation, capability and contact with the asset, and can substantially impact an asset in terms of access, modification, misuse, denying access or disclosure through a vulnerability resulting from critically flawed controls.	An issue, where threats have a significant degree of motivation, capability and contact with the asset, and can significantly impact an asset in terms of access, modification, misuse, denying access or disclosure through a vulnerability resulting from majorly flawed controls.	An issue, where threats have some degree of motivation, capability and contact with the asset, and can significantly impact an asset in terms of access, modification, misuse, denying access or disclosure through a vulnerability resulting from controls with minor flaws.	An issue that at present does not represent a risk but could do so in future.

EXECUTIVE SUMMARY

Introduction

Assuric is pleased to present the results of this security assessment to MEGI, and we would like to take the opportunity to thank all parties involved for their assistance throughout the engagement.

The assessment was performed between the 16/04/2025 and 22/04/2025, by Sasha Rajic, who can be contacted for further assistance with any of the risks detailed in this report.

Security Posture

A comprehensive security assessment, covering both the Megi web applications and their hosting infrastructure, was conducted by Assuric to verify compliance with NHS DTAC and DSPT standards. These standards require rigorous penetration testing to ensure robust security for healthcare applications. Following consultation with Megi developers and confirmation of code parity between test and production, the assessment concentrated on the test environment. This approach facilitated thorough testing in a controlled setting, anticipating that identified vulnerabilities would also exist in the live production system. Subsequently, all test findings were validated against the production system to ensure accurate and comprehensive remediation.

MEGI web applications were subject to manual and automated testing based on an extensive vulnerability checklist derived from Open Web Application Security Project (OWASP) guidelines and including the OWASP Top 10, a list of the most common and serious web application flaws.

The security assessment uncovered several vulnerabilities affecting the Megi web application. In total, eight vulnerabilities were identified, comprising five medium-risk and three low-risk issues. While no critical or high-risk vulnerabilities were discovered, the identified weaknesses still pose a potential risk to the application's security, user data, and overall integrity.

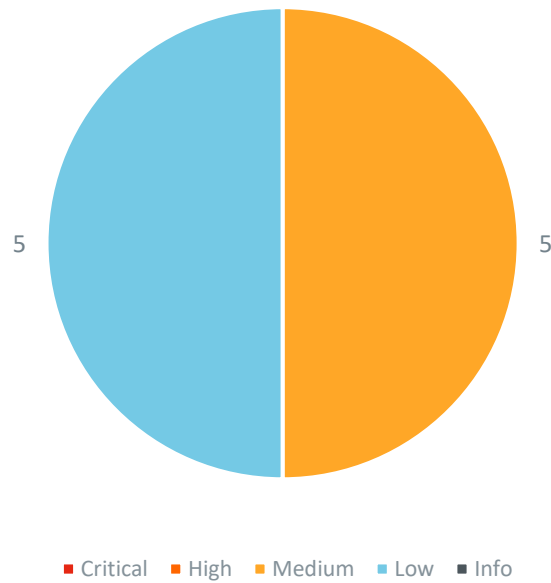
Key findings among the medium-risk issues include API access control deficiencies that permit unauthorised access to sensitive patient data, potentially violating patient privacy and confidentiality. The exposure of session tokens in URLs increases the risk of session hijacking, allowing attackers to impersonate legitimate users. The lack of session expiry mechanisms exacerbates this risk by granting persistent access even with compromised tokens. Furthermore, the disclosure of authorisation tokens within the Django admin interface, while access is restricted, represents a vulnerability that could grant widespread access if compromised. Finally, the identified vulnerable version of TinyMCE introduces the risk of cross-site scripting (XSS) attacks.

The low-risk issues include weaknesses in anti-automation controls and input validation, increasing susceptibility to brute-force and automated exploits, though exploitation is more challenging. A relaxed CORS policy, while not directly leading to data breaches, broadens the attack surface. Lastly, excessively long session timeouts, while not a direct vulnerability, prolong the potential impact of other exploits.

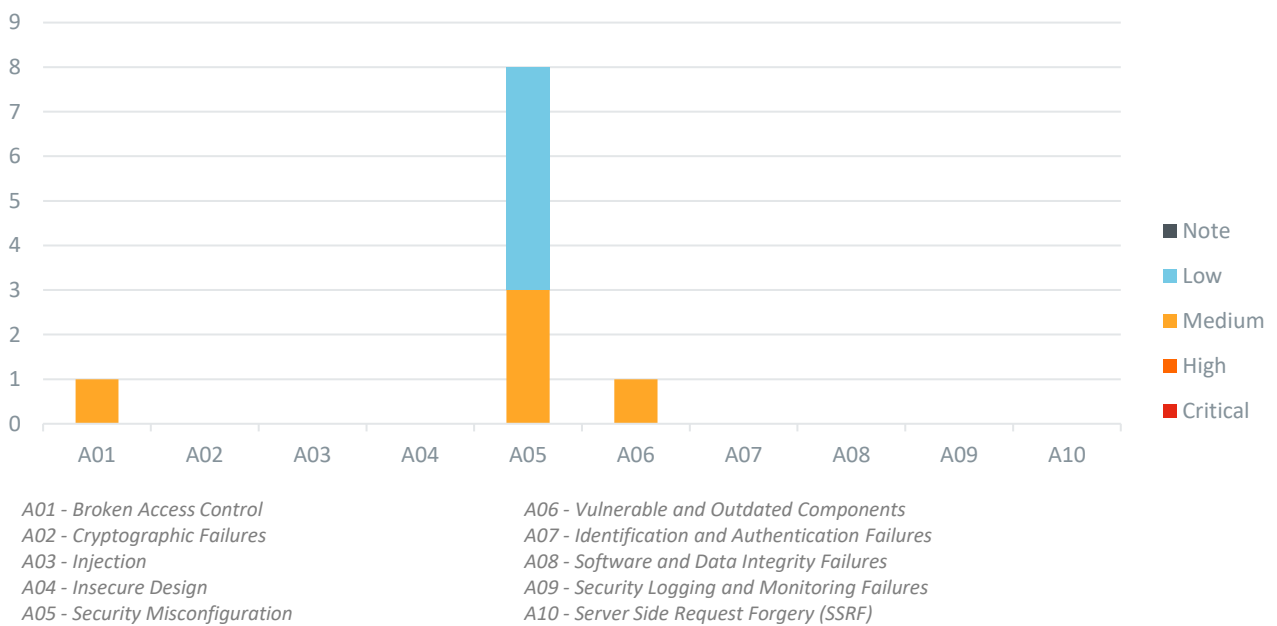
No issues were discovered with the underlying infrastructure.

While the absence of high-risk findings is positive, the identified medium and low-risk vulnerabilities still require attention. Prompt remediation is recommended to address these weaknesses and strengthen the overall security posture of the Megi application. Prioritising remediation efforts based on the potential impact of each vulnerability will effectively mitigate these risks.

Findings by Risk Ratings



Findings per category



CONCLUSIONS

Based on the findings identified during the assessment, the following prioritised list should be reviewed and actioned:

High Priority

No high priority issues were identified.

Medium Priority

- 1 Review API access controls and restrict unauthorised data retrieval
- 2 Address the identified session token vulnerabilities by implementing automatic session termination and a more secure token transmission mechanism.
- 3 Apply the latest updates to outdated third-party software components.

Low Priority

- 1 Address all identified low-risk issues in a timely manner, prioritising fixes where feasible within operational constraints. While these vulnerabilities pose a lower immediate risk, addressing them proactively strengthens the overall security posture and reduces the potential attack surface.

SCOPE OF WORK

Background

MEGI.ai is a digital assistant designed to aid patients with cardiovascular health management.

- **Patient Monitoring:** MEGI helps patients track important health metrics like blood pressure and ECG readings. It provides reminders for these measurements to ensure consistency.
- **Personalised Support:** Based on patient data, MEGI offers customised advice and protocols to improve cardiovascular health.
- **Patient Education:** The assistant provides patients with information about cardiovascular diseases, easing fears, and promoting a better understanding of their condition.
- **Improved Treatment Adherence:** MEGI's combination of tracking, reminders, and education helps patients stay on top of their prescribed treatment plans.

To meet the compliance requirement set out by the NHS, MEGI.AI has approached Assuric to perform a comprehensive penetration test against the application and the underlying infrastructure.

Targets

Target Name	Description / URL	Assessment Phase
Megi Platform	https://my-test.megi.ai/	Web Application and Infrastructure Penetration Test
Megi Admin Interface	https://my-test.megi.ai/en/admin/	
Megi Dashboard	https://dashboard-test.megi.ai/login/	
Megi API	https://my-test.megi.ai/api/docs/	
WhatsApp Chatbot	https://my.megi.ai/dc/23/	
Corporate Site	https://megi.ai	

Environment

The assessment was conducted against the test environment. Note: Megi test environment contains the same code base as the production environment. Only the underlying user data is different.

User Privileges & Credentials

Username	Privilege Level	Assessment Phase
pen_test_1	Super Admin	Web Application and API Security Assessment
pen_test_2		
gp_pen_1	GP	

gp_pen_2	MEGI Staff Doctor
staff_pen_3	
staff_pen_4	

Rules of Engagement

- Denial of Service (DoS) attacks were not carried out during the assessment. Any potential for DoS that was discovered is detailed in this report alongside recommendations to mitigate the issue.
- All identified or cracked passwords are obscured in all report output, including technical output and screenshots. Even hashed passwords are partially obscured to ensure they cannot be determined. The only exception to this rule is default passwords, which are listed for convenience (as they can be found easily through a simple Internet search).

Assessment Constraints

No issues or constraints affected the assessment.

TECHNICAL SUMMARY

Network Penetration Test

No issues or vulnerabilities were identified.

Application Penetration Test

Finding	Risk	CVSS	Remediation
API Misconfigured Access Control	Medium	6.3	Enforce strict access control checks within the API, validating user permissions before granting data access.
Session Token Passed in the URL	Medium	5.4	Transmit session tokens via HTTP headers, not in the URL.
No Session Token Expiry	Medium	5.4	Implement token expiration and renewal mechanisms.
Authorisation Token Disclosure in Django Admin Interface	Medium	4.3	Remove tokens from the admin interface and store them securely.
Vulnerable Version of TinyMCE in Use	Medium	4.3	Update TinyMCE to the latest stable release.
Lack of Anti Automation Controls	Low	3.8	Implement rate limiting and CAPTCHA challenges.
Lack of Input Validation	Low	3.8	Sanitise all user inputs server-side.
Relaxed CORS Policy	Low	3.5	Restrict allowed origins to a predefined list of trusted domains.
Missing Cookie Security Directive	Low	2.7	Set the HTTPOnly and Secure flags for all cookies.
Long Session Timeout	Low	2.7	Reduce session timeout duration to a reasonable timeframe.

ASSESSMENT FINDINGS

Application Penetration Test

API Misconfigured Access Control

Status	Open
Control	OWASP - A01 - Broken Access Control
CVSS	6.3
Severity	Medium

Description

This vulnerability pertains to inadequate access control within the API. Authorised users, specifically GPs, can access patient data belonging to other GPs' patients. While arbitrary data extraction was not observed, sensitive information like blood pressure readings could be retrieved by manipulating patient user IDs within API requests. The vulnerability stems from insufficient validation of user permissions during data retrieval. The impact includes unauthorised access to patient medical information, potentially violating patient privacy and confidentiality regulations. This could lead to reputational damage, legal repercussions, and erosion of patient trust. The sequential nature of user IDs, with variations primarily in the last few digits, further exacerbates the issue by allowing attackers to easily enumerate valid IDs and potentially gain unauthorised access to patient records. Though authentication is required to interact with the API, the lack of granular access control based on GP-patient assignments renders this protection insufficient.

Technical Output

The following HTTP request demonstrates GP Pen2 retrieving information about a user assigned to GP Pen1:

```
GET /api/v1/readings/?user=100000204&start_date=2025-04-01&end_date=2025-04-15&page_size=100&page=1&time_of_day= HTTP/2
```

Host: my-test.megi.ai

Sec-Ch-Ua-Platform: "Windows"

Authorization: Token d8e06052717e90049faf03365b0e1c81c31caa58

Accept-Language: en

Accept: application/json, text/plain, */*

Sec-Ch-Ua: "Chromium";v="135", "Not-A.Brand";v="8"

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36

Sec-Ch-Ua-Mobile: ?0

Origin: https://dashboard-test.megi.ai

Sec-Fetch-Site: same-site

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: <https://dashboard-test.megi.ai/>
 Accept-Encoding: gzip, deflate, br
 Priority: u=1, i

Response:

HTTP/2 200 OK
 Date: Tue, 15 Apr 2025 18:38:59 GMT
 Content-Type: application/json; charset=utf-8
 Content-Length: 588
 Server: nginx
 Vary: Accept, origin, Accept-Language
 Allow: GET, POST, HEAD, OPTIONS
 X-Frame-Options: DENY
 Access-Control-Allow-Origin: *
 Content-Language: en
 X-Content-Type-Options: nosniff
 Referrer-Policy: same-origin
 Cross-Origin-Opener-Policy: same-origin

```
{
  "count": 2,
  "next": null,
  "previous": null,
  "results": [
    {
      "user": "100000204",
      "systolic_pressure": 130,
      "diastolic_pressure": 77,
      "pulse": 67,
      "created_at": "2025-04-15T17:35:41.755687Z",
      "ht_protocol": null,
      "evaluated_blood_pressure": "high_normal",
      "has_difficulties": true,
      "time_of_day": "evening",
      "user_difficulties": ["Severe difficulties"]
    },
    {
      "user": "100000204",
      "systolic_pressure": 210,
      "diastolic_pressure": 120,
      "pulse": 90,
      "created_at": "2025-04-15T16:33:50.876178Z",
      "ht_protocol": 188,
      "evaluated_blood_pressure": "ER",
      "has_difficulties": true,
      "time_of_day": "evening",
      "user_difficulties": ["Severe difficulties"]
    }
  ]
}
```

The request issued above seems to obtain every historical blood pressure reading. Similarly, patient stats could also be obtained – as demonstrated below. Please note that all HTTP requests are issued as GP Pen2.

GET /api/v1/readings-stats/?user=100000204&start_date=2024-04-15&end_date=2025-04-15
 HTTP/2
 Host: my-test.megi.ai
 Sec-Ch-Ua-Platform: "Windows"
 Authorization: Token d8e06052717e90049faf03365b0e1c81c31caa58
 Accept-Language: en
 Accept: application/json, text/plain, */*
 Sec-Ch-Ua: "Chromium";v="135", "Not-A.Brand";v="8"
 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
 Sec-Ch-Ua-Mobile: ?0
 Origin: <https://dashboard-test.megi.ai>

Sec-Fetch-Site: same-site
 Sec-Fetch-Mode: cors
 Sec-Fetch-Dest: empty
 Referer: https://dashboard-test.megi.ai/
 Accept-Encoding: gzip, deflate, br
 Priority: u=1, i

Response:

HTTP/2 200 OK
 Date: Tue, 15 Apr 2025 19:17:38 GMT
 Content-Type: application/json; charset=utf-8
 Content-Length: 1235
 Server: nginx
 Vary: Accept, origin, Accept-Language
 Allow: GET, HEAD, OPTIONS
 X-Frame-Options: DENY
 Access-Control-Allow-Origin: *
 Content-Language: en
 X-Content-Type-Options: nosniff
 Referrer-Policy: same-origin
 Cross-Origin-Opener-Policy: same-origin

```
{
  "avg_systolic":176,"min_systolic":130,"max_systolic":210,"avg_systolic_morning":null,"avg_systolic_e
  vening":176,"avg_diastolic":122,"min_diastolic":77,"max_diastolic":170,"avg_diastolic_morning":null,"a
  vg_diastolic_evening":122,"avg_pulse":96,"min_pulse":67,"max_pulse":130,"min_systolic_morning":null
  ,"max_systolic_morning":null,"min_diastolic_morning":null,"max_diastolic_morning":null,"min_systolic_
  evening":130,"max_systolic_evening":210,"min_diastolic_evening":77,"max_diastolic_evening":170,"rea
  dings_total":3,"readings_optimal":0,"readings_normal":0,"readings_high_normal":1,"readings_grade_1_
  hypertension":0,"readings_grade_2_hypertension":0,"readings_grade_3_hypertension":0,"readings_er
  ":2,"readings_morning_total":0,"readings_morning_optimal":0,"readings_morning_normal":0,"readings
  _morning_high_normal":0,"readings_morning_grade_1_hypertension":0,"readings_morning_grade_2_hy
  pertension":0,"readings_morning_grade_3_hypertension":0,"readings_morning_er":0,"readings_evenin
  g_total":3,"readings_evening_optimal":0,"readings_evening_normal":0,"readings_evening_high_normal
  ":1,"readings_evening_grade_1_hypertension":0,"readings_evening_grade_2_hypertension":0,"readings
  _evening_grade_3_hypertension":0,"readings_evening_er":2}

```

The same request could not be issued through the front end. In other words, changing patient ID produced a 404 error.

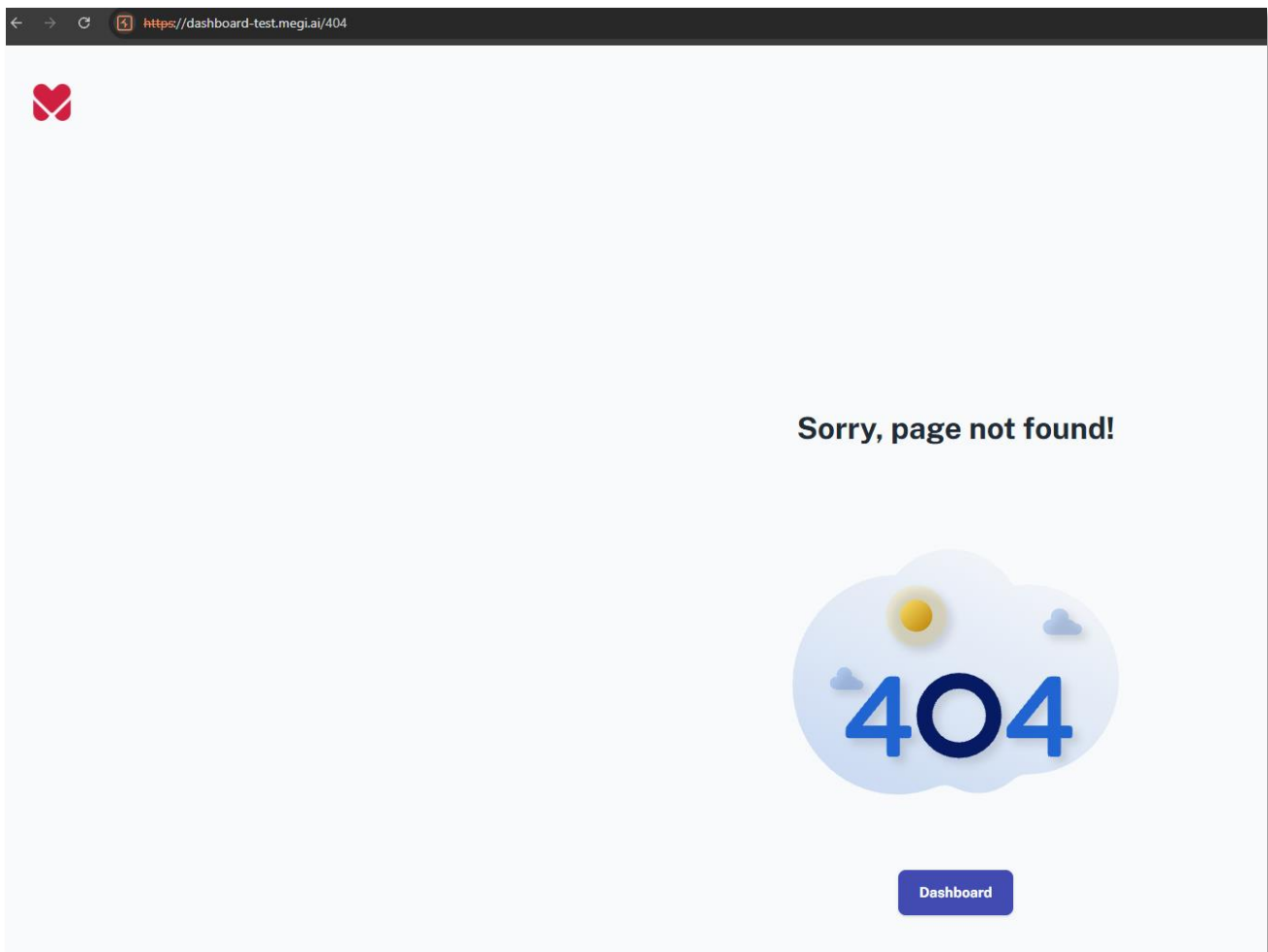


Figure 1- Access Denied Through Application Frontend

In addition, staff_pen_4 user was also able to obtain the same information about a patient assigned to GP Pen_1.

Remediation

Implement robust access control checks within the API logic. Validate user permissions before granting access to patient data, ensuring that only the assigned GP can retrieve information for their patients. Consider adopting a UUID-based system instead of sequential numerical identifiers for patient records. This will significantly hinder attempts to guess or enumerate valid IDs.

Affected Components

Megi Dashboard, specifically APIs responsible for retrieving blood pressure reading and blood pressure stats.

References

[A01:2021 – Broken Access Control](#)

Session Token Passed in the URL

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	5.4
Severity	Medium

Description

The WhatsApp bot, used for uploading images and therapy information, transmits session tokens within the URL. This practice poses a significant security risk. If a URL containing a token is leaked, unauthorised individuals could potentially gain access to uploaded images. The impact of this vulnerability includes unauthorised access to sensitive user data, potentially violating privacy regulations and leading to reputational damage. This vulnerability is exacerbated by the various ways URLs can be exposed, such as browser history, logs, or network sniffing.

Technical Output

The following URL was issued by the WhatsApp chat bot after the images were uploaded:

https://dashboard-test.megi.ai/therapy/main_menu_v2/5df063cfaf0d19b59ba87cdca075cc49c36a06e3

Remediation

Consider transmitting session tokens via alternative methods such as hidden fields in POST requests or cookies. A better method would be to force users to register and authenticate before they can upload images. A one-time token is acceptable; however, in this instance the token issued does not seem to expire.

Affected Components

Megi Dashboard File / Photo Upload Functionality

References

[OWASP - Session Management Cheat Sheet](#)

No Session Token Expiry

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	5.4
Severity	Medium

Description

The session tokens used by the WhatsApp bot for uploading images and therapy information do not expire. This creates a persistent security risk, as a compromised token remains valid indefinitely, granting an attacker continuous access to sensitive user data. The impact of this vulnerability includes prolonged unauthorised access to uploaded images. Even if a user becomes aware of a compromised token, they lack the ability to revoke it, leaving their data vulnerable.

Please note: *While a mechanism exists to revoke session tokens via an API logout function, this method is not readily accessible to end-users.*

Technical Output

WhatsApp Chat bot issued tokens remained valid for the duration of the assessment.

Remediation

Implement token expiration mechanisms. Establish a reasonable expiry duration based on the sensitivity of the data and user activity patterns. Introduce a mechanism for users to manually revoke tokens, granting them control over their session security.

Affected Components

WhatsApp Chat Bot Generated Tokens for Image / File Upload

References

[OWASP - Session Management Cheat Sheet](#)

Authorisation Token Disclosure in Django Admin Interface

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	4.3
Severity	Medium

Description

Authorisation tokens are exposed within the Django admin interface. Given the application's reliance on tokens as the sole authentication mechanism for users, doctors, and staff, this exposure presents a significant security risk. Compromise of administrative accounts with access to the Django admin portal could lead to the theft of these tokens, granting an attacker unauthorised access to sensitive user data. While access to the admin interface is restricted, any compromise of these privileged accounts would have severe consequences due to the full access granted by the exposed tokens. In addition, any disgruntled employee with administrative privileges could impersonate any user configured on the application.

Technical Output

The following screenshot demonstrates the finding:

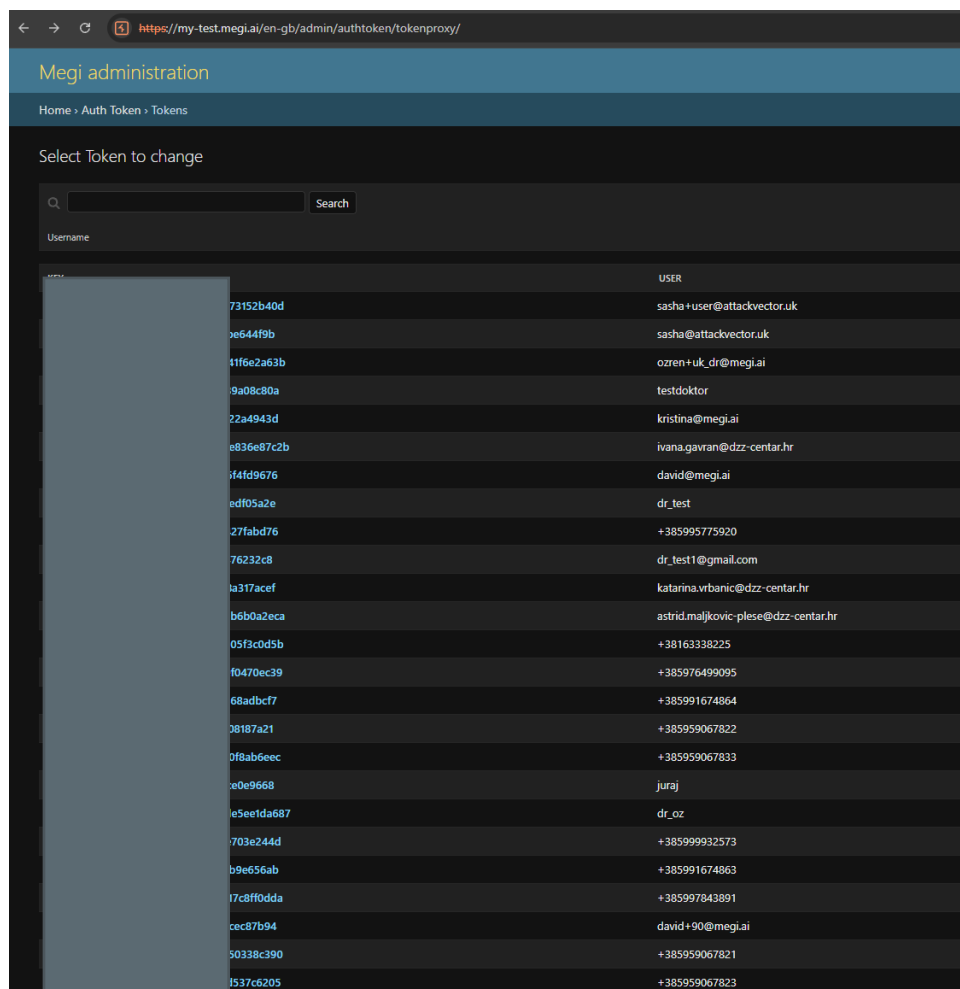


Figure 2 - Auth Token Disclosure

Remediation

Remove authorisation tokens from the Django admin interface. Store tokens securely using a robust encryption method and avoid displaying them in any accessible interface. Restrict which users are able to log into the Django admin interface.

Affected Components

<https://my-test.megi.ai/en/admin/>

References

[The Django admin site](#)

[OWASP - Authorization Cheat Sheet](#)

Vulnerable Version of TinyMCE in Use

Status	Open
Control	OWASP - A06 - Vulnerable and Outdated Components
CVSS	4.3
Severity	Medium

Description

A cross-site scripting (XSS) vulnerability exists in TinyMCE versions prior to 6.8.5 due to a bypass in DOMPurify. This vulnerability arises from inconsistent parsing of invalid HTML elements within XML contexts between DOMPurify and the browser. This discrepancy allows malicious scripts to bypass sanitisation, potentially enabling attackers to inject and execute arbitrary JavaScript code in the context of vulnerable TinyMCE instances. The impact includes the potential for session hijacking, data theft, redirection to malicious websites, and defacement of web pages.

Technical Output

The following screenshot demonstrates the version of TinyMCE in use:

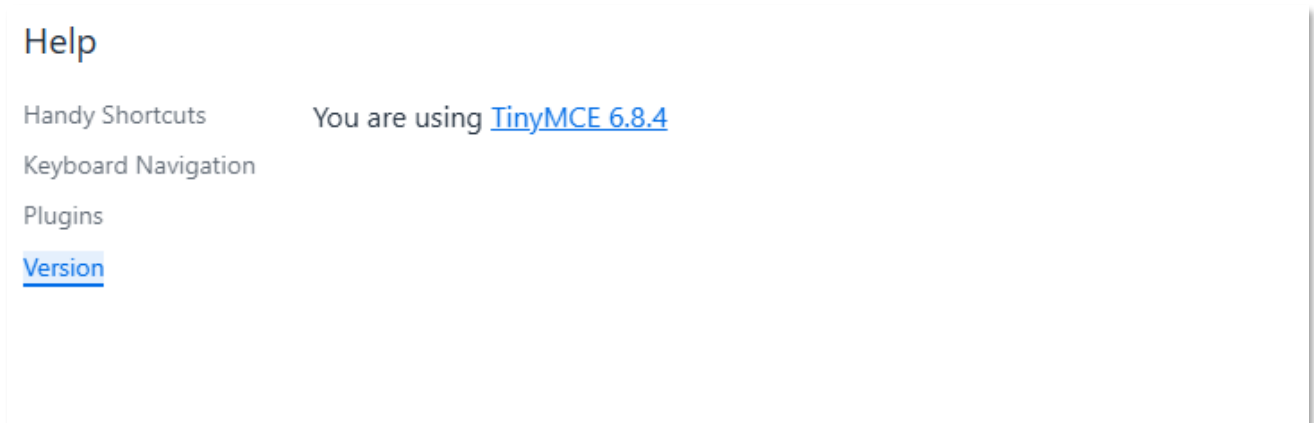


Figure 3 - TinyMCE Version

Remediation

Upgrade TinyMCE to its latest version, which at the time of writing is 6.8.5

Affected Components

<https://my-test.megi.ai/en/admin/>

References

[TinyMCE 6.8.5](#)

[CVE-2024-45801](#)

Lack of Anti Automation Controls

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	3.8
Severity	Low

Description

The application lacks adequate anti-automation controls. This weakness allows for rapid enumeration of potential user accounts by simply iterating through user IDs, particularly by modifying the final four characters. This vulnerability exposes the application to brute-force attacks targeting user accounts and potentially facilitates unauthorised access. This issue is made worse as the API in question also fails to implement adequate user access control.

Technical Output

The following screenshot demonstrates 10000 requests in a space of a couple of minutes attempting to enumerate user information

Request	Payload	Status code	Response received	Error	Timeout	Length
2535	2534	400	156			482
2536	2535	400	234			482
2537	2536	400	236			482
2538	2537	400	236			482
2539	2538	400	215			482
2540	2539	400	189			482
2541	2540	400	262			482
2542	2541	400	189			482
2543	2542	400	174			482
2544	2543	400	231			482
2545	2544	400	183			482
2546	2545	400	136			482
2547	2546	400	206			482

Request	Response
pretty	Raw Hex
	<pre> GET /api/v1/screening/status/?user=100002541&page_size=100&page=1 HTTP/2 Host: my-test.megi.ai Sec-Ch-Ua-Platform: "Windows" Authorization: Token cc59283546b1a5f93b79a5d1c0f61cf41b61c54a Accept-Language: en Accept: application/json, text/plain, */* Sec-Ch-Ua: "Chromium";v="135", "Not-A.Brand";v="8" User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36 Sec-Ch-Ua-Mobile: ?0 Origin: https://dashboard-test.megi.ai Sec-Fetch-Site: same-site Sec-Fetch-Mode: cors Sec-Fetch-Dest: empty Referer: https://dashboard-test.megi.ai/ Accept-Encoding: gzip, deflate, br Priority: u=1, i Connection: keep-alive </pre>

Figure 4 - Lack of Anti Automation

Remediation

Implement rate limiting to restrict the number of requests from a single IP address within a specific timeframe. Introduce CAPTCHA challenges or similar mechanisms to differentiate between human users and automated scripts. Monitor login attempts for suspicious patterns indicative of brute-force or enumeration attacks.

Affected Components

<https://my-test.megi.ai>

<https://dashboard-test.megi.ai>

References

[OWASP Automated Threats to Web Applications](#)

Lack of Input Validation

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	3.8
Severity	Low

Description

A potential reflected cross-site scripting (XSS) vulnerability was identified where the application echoes user-supplied input containing XSS payloads within the JSON response. However, due to the context of the JSON response and the lack of direct rendering by the browser, this vulnerability is not currently exploitable. While the application echoes potentially malicious input, the JSON format itself prevents direct execution of the embedded scripts within a standard web browser.

Technical Output

The following is an example HTTP request where user input was not modified:

```
POST /api/v1/events/ HTTP/2
Host: my-test.megi.ai
Content-Length: 57
Sec-Ch-Ua-Platform: "Windows"
Authorization: Token 5df063cfaf0d19b59ba87cdca075cc49c36a06e3
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Chromium";v="135", "Not-A.Brand";v="8"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/135.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Content-Type: application/json
Origin: https://dashboard-test.megi.ai
Sec-Fetch-Site: same-site
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://dashboard-test.megi.ai/
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
```

```
{"flow":"main_menu_v2","event":"therapy - saved dosagesaaous<script>alert(1)</script>vn6am"}
```

Response

```
HTTP/2 201 Created
Date: Tue, 15 Apr 2025 16:52:08 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 109
Server: nginx
Vary: Accept, origin, Accept-Language
Allow: POST, OPTIONS
X-Frame-Options: DENY
```

Access-Control-Allow-Origin: *
 Content-Language: en-gb
 X-Content-Type-Options: nosniff
 Referrer-Policy: same-origin
 Cross-Origin-Opener-Policy: same-origin

```
{"user":100000204,"flow":"main_menu_v2","event":"therapy - saved
dosagesaaous<script>alert(1)</script>vn6am"}
```

Example HTTP Request:

```
GET /api/v1/readings/?user=100000204&start_date=2025-04-01&end_date=2025-04-
15&page_size=100&page=1&time_of_day=eveninghfs7r%3cscript%3ealert(1)%3c%2fscript%3epuzry
HTTP/2
Host: my-test.megi.ai
Sec-Ch-Ua-Platform: "Windows"
Authorization: Token f88b2e6d3f12f2c2bd17c321f5742f5993f6b977
Accept-Language: hr
Accept: application/json, text/plain, */*
Sec-Ch-Ua: "Chromium";v="135", "Not-A.Brand";v="8"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/135.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Origin: https://dashboard-test.megi.ai
Sec-Fetch-Site: same-site
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://dashboard-test.megi.ai/
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
```

Response:

```
HTTP/2 400 Bad Request
Date: Tue, 15 Apr 2025 17:47:53 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 113
Server: nginx
Vary: Accept, origin, Accept-Language
Allow: GET, POST, HEAD, OPTIONS
X-Frame-Options: DENY
Access-Control-Allow-Origin: *
Content-Language: hr
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
```

```
{"time_of_day":["Odaberite iz ponuđenog. eveninghfs7r<script>alert(1)</script>puzry nije
ponuđen kao opcija."]}
```

Remediation

Implement robust input validation on the server-side to sanitise all user-supplied data before including it in the JSON response. This preventative measure will mitigate the risk of future exploits if the

context of the JSON handling changes. Encode special characters (e.g., <, >, ", ') within the JSON values as a defence-in-depth measure.

Affected Components

<https://my-test.megi.ai>

References

[Cross Site Scripting Prevention Cheat Sheet](#)

Relaxed CORS Policy

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	3.5
Severity	Low

Description

The application's Cross-Origin Resource Sharing (CORS) policy allows users to insert arbitrary trusted origins. This misconfiguration poses a security risk as it effectively disables the intended access controls of the CORS mechanism. By specifying arbitrary origins, an attacker can bypass the same-origin policy restrictions enforced by browsers, enabling unauthorised cross-origin requests to the application. The impact includes potential data exfiltration, manipulation of application functionality through cross-origin requests, and increased vulnerability to cross-site scripting (XSS) attacks.

Technical Output

The below output demonstrates the relaxed CORS policy.

Request:

```
GET /api/v1/screening/status/?user=100000097&page_size=100&page=1 HTTP/2
Host: my-test.megi.ai
Sec-Ch-Ua-Platform: "Windows"
Authorization: Token cc59283546b1a5f93b79a5d1c0f61cf41b61c54a
Accept-Language: en
Accept: application/json, text/plain, */*
Sec-Ch-Ua: "Chromium";v="135", "Not-A.Brand";v="8"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Origin: https://attackvector.uk
Sec-Fetch-Site: same-site
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://dashboard-test.megi.ai/
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
```

Response:

```
HTTP/2 200 OK
Date: Tue, 22 Apr 2025 19:36:41 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 52
Server: nginx
Vary: Accept, origin, Accept-Language
```

Allow: GET, POST, HEAD, OPTIONS

X-Frame-Options: DENY

*Access-Control-Allow-Origin: **

Content-Language: en

X-Content-Type-Options: nosniff

Referrer-Policy: same-origin

Cross-Origin-Opener-Policy: same-origin

```
{"count":0,"next":null,"previous":null,"results":[]}
```

Remediation

Restrict the allowed origins within the CORS policy to a specific, predefined list of trusted domains. Avoid using wildcards or allowing user-supplied input to define allowed origins.

Affected Components

<https://my-test.megi.ai>

References

[Testing Cross Origin Resource Sharing](#)

Missing Cookie Security Directive

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	2.7
Severity	Low

Description

The application fails to set the HTTPOnly and Secure flags for its cookies. This omission weakens the security of the application by exposing cookies to potential compromise through client-side scripts and insecure network connections. Without the HTTPOnly flag, cookies are accessible to JavaScript code, making them vulnerable to theft via cross-site scripting (XSS) attacks. The absence of the Secure flag allows cookies to be transmitted over unencrypted HTTP connections, exposing them to interception during transit. The impact includes potential session hijacking, unauthorised access to user accounts, and disclosure of sensitive information stored within the cookies.

Technical Output

The following cookies were issued by the application and do not have one of the cookie directives set:

- CsrfToken (missing HTTPOnly and Secure Flag)
- Sessionid (missing Secure flag only)

The HTTP response demonstrates the findings:

HTTP/2 200 OK

Date: Tue, 15 Apr 2025 12:27:01 GMT

Content-Type: text/html; charset=utf-8

Content-Length: 2516

Server: nginx

Expires: Tue, 15 Apr 2025 12:27:01 GMT

Cache-Control: max-age=0, no-cache, no-store, must-revalidate, private

Vary: Cookie, origin, Accept-Language

X-Frame-Options: DENY

Content-Language: en-gb

X-Content-Type-Options: nosniff

Referrer-Policy: same-origin

Cross-Origin-Opener-Policy: same-origin

Set-Cookie: csrfToken=aFoBDeLJuBJi3UfEIVpOkqzv3Mv0f2gd; expires=Tue, 14 Apr 2026 12:27:01 GMT; Max-Age=31449600; Path=/; SameSite=Lax

Set-Cookie: sessionid=94lpo6nl315sba01nwns92p5tfdqj3yo; expires=Tue, 29 Apr 2025 12:27:01 GMT; HttpOnly; Max-Age=1209600; Path=/; SameSite=Lax

Remediation

Set the HTTPOnly flag for all cookies to prevent client-side JavaScript from accessing them. Set the Secure flag for all cookies to ensure they are only transmitted over HTTPS connections. Ensure all pages using these cookies are served over HTTPS to prevent the Secure flag from blocking cookie transmission. Regularly review and update cookie security attributes to maintain best practices and address evolving security threats.

Affected Components

<https://my-test.megi.ai>

References

[OWASP – Session Management Cheat Sheet](#)

Long Session Timeout

Status	Open
Control	OWASP - A05 - Security Misconfiguration
CVSS	2.7
Severity	Low

Description

The application did not appear to have an idle session timeout mechanism in place. Sessions were left logged in for varying time periods (over a couple of hours) without session termination occurring. The impact of this is that a threat actor with access to the session, either through physical access or a session-based attack, could operate the application under the context of the logged-in user. This access could potentially be utilised to obtain sensitive information, modify information or cause a denial-of-service type condition through deletion of data.

Prolonged idle sessions increase the window of opportunity for attackers. This is the case for both physical access and session-based attacks. However, in both instances, access to the user's host/browser or access to a user's session token is required to leverage this issue as part of an attack.

Technical Output

The following cookie properties were observed

Set-Cookie: csrftoken=aFoBDeLJuBJi3UfEIVpOkqzv3Mv0f2gd; expires= **Tue, 14 Apr 2026** 12:27:01 GMT; Max-Age=31449600; Path=/; SameSite=Lax

Set-Cookie: sessionid=94lpo6nl315sba01nwns92p5tfdqj3yo; expires= **Tue, 29 Apr 2025** 12:27:01 GMT; HttpOnly; Max-Age=1209600; Path=/; SameSite=Lax

Remediation

It is recommended that an idle session timeout value is set for all authenticated sessions. Ideally, for an application of this nature, this should be set to 30 minutes.

Affected Components

<https://my-test.megi.ai>

References

[OWASP – Automatic Session Expiration](#)

External Network Penetration Test

No issues or misconfigurations were discovered on the external facing infrastructure.

Appendix A - OWASP Top 10 Web Application Security Risks

This section provides a convenient summary of the application's adherence to industry standard best practices as outlined by OWASP, a worldwide not-for-profit organisation with the aim of increasing the visibility of software security practices: <https://www.owasp.org>

Specifically, the application has been scored against the OWASP Web Application Top 10, a list comprising a broad consensus of the most critical security risks to web applications:

https://www.owasp.org/index.php/Category:OWASP_Top_Ten_Project

OWASP Top 10 Category	Pass/Fail	Comments
A01:2021 - Broken Access Control	Improvement	API permissions seem to be misconfigured and allow unauthorised retrieval of patient data.
A02:2021 - Cryptographic Failures	Pass	No Instances Identified
A03:2021 - Injection	Pass	No Instances Identified
A04:2021 - Insecure Design	Pass	No Instances Identified
A05:2021 - Security Misconfiguration	Improvement	Various security misconfiguration related issues were observed.
A06:2021 - Vulnerable and Outdated Components	Improvement	TinyMCE was found to be vulnerable and outdated.
A07:2021 - Identification and Authentication Failures	Pass	No Instances Identified
A08:2021 - Software and Data Integrity Failures	Pass	No Instances Identified
A09:2021 - Security Logging and Monitoring Failures	Pass	No Instances Identified
A10:2021 - Server-Side Request Forgery	Pass	No Instances Identified

CYBER SECURITY CERTIFICATIONS



A Chartered Cyber Security Professional (ChCSP) possesses extensive practical knowledge across multiple specialisms and is recognised as an expert in at least one of these areas. Operating at a senior level, they are expected to contribute to the advancement of the wider cyber security profession through their informed professional judgement. Such individuals demonstrate strong communication and interpersonal skills, enabling them to engage effectively at all levels within and outside an organisation, whether with peers or non-specialists. Chartered professionals uphold the highest standards of integrity, ethics, and moral values and display a strong commitment to ongoing personal development and the continued evolution of the cyber security profession.



Attack Vector's penetration testers hold the prestigious Cyber Scheme Team Leader (CSTL) certification in infrastructure, one of the highest qualifications in the industry. The Cyber Scheme is one of only two organisations—alongside CREST—accredited by the UK's National Cyber Security Centre (NCSC) to deliver examinations that meet UK Government standards for penetration testing.



Attack Vector holds multiple CompTIA certifications, which are highly respected within the IT industry. These qualifications demonstrate proven expertise across various areas of information technology and cyber security. CompTIA certifications are recognised worldwide and reflect a strong commitment to professional standards and best practices.